

Assignment Continuation: Part E — Authentication & Authorization (Laravel + Spatie Permissions)

This is a continuation of the existing Products CRUD API assignment (Parts A–D).

Goal

Enhance the same project by adding:

1. **Authentication** (API login using token-based auth)
2. **Authorization** (role/permission access control using **spatie/laravel-permission**)

Part E (30 marks)

E1: Git workflow (5 marks)

1. Make sure your main (or master) branch is clean and pushed.
2. Create a new branch:
 - feature/authz-spatie
3. Do all work in this branch and push it.

Deliverable

- Screenshot of git branch showing the new branch name + latest commit.

E2: Authentication (10 marks)

Implement token-based authentication for API users.

Requirements

- Add API endpoints:
 - POST /api/auth/register
 - POST /api/auth/login
 - POST /api/auth/logout (requires auth)
 - GET /api/auth/me (requires auth)
- All responses must be JSON with correct HTTP status codes:
 - 201 for successful registration
 - 200 for success
 - 401 for unauthenticated requests
 - 422 for validation errors

Suggested approach

- Use **Laravel Sanctum** for token auth (personal access tokens).

Deliverables

- Auth controller(s) (e.g. app/Http/Controllers/Auth/*)
- Updated routes/api.php
- Screenshot of successful auth flow tests in Bruno (see E4)

E3: Authorization with Spatie Permissions (15 marks)

Use **spatie/laravel-permission** to enforce permissions on product endpoints.

Step 1: Install & setup

- Install spatie/laravel-permission
- Publish config/migrations
- Run migrations
- Ensure User model uses HasRoles

Step 2: Define roles & permissions

Create at least these permissions:

- products-view
- products-create
- products-update
- products-delete

Create at least these roles (you may add more):

- **admin**: all product permissions
- **staff**: view, create, update
- **viewer**: view only

Step 3: Seed roles & permissions

- Create a seeder (recommended) to generate roles & permissions.
- Assign a role to a user (either via seeder, tinker, or a protected admin route).

Step 4: Protect Product routes

Update /api/products* routes so that:

- All product endpoints require authentication.
- Permissions are enforced:
 - GET /api/products and GET /api/products/{id} → products-view
 - POST /api/products → products-create
 - PUT /api/products/{id} → products-update
 - DELETE /api/products/{id} → products-delete

Expected behavior

- Unauthenticated request → 401 Unauthorized
- Authenticated but missing permission → 403 Forbidden
- Authorized → normal success status codes (200/201 etc.)

Deliverables

- Seeder file(s) (roles/permissions)
- Proof in code: middleware/policies/gates (your choice), but must use Spatie permissions.
- Screenshot of successful php artisan migrate / db:seed output.

E4: API Testing with Bruno (required for Part E)

Provide screenshots (request + response) for these:

1. Register a user → 201

2. Login and obtain token → 200
3. Access GET /api/auth/me without token → 401
4. Access GET /api/auth/me with token → 200
5. Access POST /api/products as **viewer** → 403
6. Access GET /api/products as **viewer** → 200
7. Access POST /api/products as **admin** (or staff) → 201
8. Logout → 200

Put all screenshots in screenshots/ folder (continue the same style from Part D).

Submission checklist (updated)

Continue using the same repo rules (public GitHub repo, README, .env.example, screenshots folder).

Make sure:

- Code is pushed (including the new branch)
- README includes **how to run migrations + seed roles/permissions**
- Auth + permission enforcement works as specified
- Bruno screenshots for Part E are complete